NANNY-APP · PRODUCT & ENGINEERING

# Professional Engineering Audit

Evidence-based review of the web app, Android app, API, database, delivery process and project vision.

Version 1.0 20 October 2026 Status: prototype hardening

## 1. Executive summary

> **Overall assessment: 6.2/10.** Nanny-App is a functional prototype with substantial implemented scope across web, Android, API and database layers. It is not yet production-ready because live configuration, credential hygiene, physical-device evidence, recovery operations and a small number of test/documentation gaps remain open.

The central vision remains sound: help parents find trusted childcare, help nannies manage care work, and give administrators the controls needed for verification, support and dispute handling. The next stage should prioritise trust and reliability evidence over adding broad new features.

## 2. Audit scorecard

| Area | Score | Finding |
| --- | --- | --- |
| Architecture, frontend, backend and database | 7/10 | Clear web/mobile/shared separation and broad workflows; duplicated client logic and deployment drift remain. |

| | | |
|---|---|---|
| Security and authentication | 6/10 | Password hashing, bearer tokens, CSRF and role checks exist; exposed credentials, public demo markup and live mismatch require remediation. |
| API and media integration | 6/10 | Broad API coverage and ownership checks exist; physical-device media/readback and live URL configuration need proof. |
| Testing, UI and accessibility | 7/10 | Useful automated checks and coherent UI exist; the full suite has a backend bearer-policy failure and device evidence is incomplete. |
| Documentation, DevOps and release | 6/10 | Strong planning documents and CI workflow exist; README drift and unverified production/backup/monitoring gates reduce confidence. |
| Production readiness | 4/10 | Not approved for public launch until secrets, live configuration, email, monitoring, recovery and real-device acceptance are complete. |

# 3. Evidence reviewed

- PHP web app in `NannyApp.Web`, Android/Compose client in `NannyApp.Mobile/NannyApp`, shared database/storage layer in `NannyApp.Shared`, tests, scripts and GitHub Actions.
- Approximately 31 table definitions and 27 foreign-key relationships, with migration order/checksum documentation.
- Android configuration using compile SDK 36, min SDK 26 and target SDK 35; a historical build log exists, but the current environment lacks Java/JAVA_HOME for a fresh build.
- Automated checks passed for syntax and many feature areas, while the full backend suite stopped at `tests/security/backend.php` with an unverified bearer-policy failure.
- Existing documentation, release files, deployment plans and live-site configuration were compared for consistency.

# 4. Priority risk register

| Priority | Risk | Required response |
|---|---|---|
| P0 | Secrets supplied in project context may be compromised. | Rotate Supabase database, service-role, JWT and related credentials; remove them from shared or committed artefacts; verify logs and access. |

| | | |
|---|---|---|
| P0 | Demo account password is exposed in delivered HTML/live markup. | Use private seeded demo credentials or a controlled reset flow; never render passwords in page source. |
| P1 | Mobile/web account and media behaviour depends on live configuration and physical-device conditions. | Run an HTTPS Android acceptance pass for registration, login, profile image upload/readback, session sharing and logout. |
| P1 | Concurrent registration can turn a duplicate email into a generic server error. | Return a controlled conflict after the database race; this audit's first implementation change addresses this. |
| P1 | Recovery, monitoring and restore evidence is incomplete. | Record an isolated database/upload restore drill, health check, queue alert and rollback result. |
| P2 | Documentation and generated artefacts have drifted. | Keep the numbered documentation suite, README files and CI checks aligned with one current release baseline. |

# 5. Project vision update

Trust

### Verified care discovery

Protect parent and child information, verify nanny evidence, and make status and support paths understandable.

Reliability

### One account across channels

Registration, login, profile data, images and sessions must behave consistently on web and physical Android devices.

Evidence

### Demonstrable delivery

Every marked feature needs a reproducible test, device recording or operational proof rather than a documentation-only claim.

Responsible pilot

### Safe operations

Manual payment states, private media, support queues, audit logs, backups and rollback remain explicit pilot boundaries.

**Vision decision:** the next release is a reliability-and-evidence release. Securing configuration, proving the mobile-to-database path, clearing the backend test failure and documenting release gates take priority over broad new features.

# 6. Updated roadmap

### P0 · Immediate

Rotate exposed credentials; remove public demo passwords; align live environment variables; preserve only safe public keys in clients.

### P1 · This iteration

Handle duplicate registration races; fix the bearer-policy test; verify mobile registration/login/profile-image upload and readback over HTTPS; add a controlled demo-account procedure.

### P1 · Release evidence

Run Android on a physical phone, capture the feature video, validate email verification, run accessibility checks and record database/API/authentication evidence without exposing secrets.

### P2 · Operational maturity

Complete restore drill, external monitoring, queue alerts, dependency review, image-storage scaling plan and documentation reconciliation.

# 7. Change implemented after the audit

> **Registration conflict hardening completed.** Both web and mobile registration endpoints now roll back safely and re-check the email after a failed insert. If another request won the race, the user receives a clear duplicate-account conflict instead of a misleading HTTP 500 response.

This is a small, low-risk first change that improves the account contract for both clients without changing passwords, authentication tokens or database schema. The next recommended change is P0 credential/demo-account remediation, followed by a physical Android media/readback acceptance test.

# 8. Audit conclusion

Nanny-App is suitable for continued prototype development and assessment demonstration once the known configuration and test issues are clearly labelled. It should not be described as production-ready until the

P0/P1 actions above are evidenced. The project has a credible foundation; the immediate goal is to make its trust, reliability and release claims verifiable.

Nanny-App · Care · Connect · Comfort · Audit and vision update